



Web applications are susceptible to various types of attacks from numerous directions. Hackers would love to gain unauthorised access to information. This is where Web application security enters the picture, to prevent these attacks. This article takes a look at how confidential information can be accessed by attackers, and suggests how to prevent this from happening.

The confidentiality, integrity and availability of information, also known as the 'CIA triad', is a model that guides the information security policy in an organisation. Confidentiality of the information relates to privacy. The integrity of information implies that only authorised personnel should be able to edit the data. And availability is being able to access the information easily and at any time. Anything compromising the CIA triad is dangerous for the organisation. Nowadays, almost all organisations have websites. Any misconfiguration in the Web server or the website might cause a major information leak and breach of security.

Consider a firm named MyCompany, hosting a website with flaws that an attacker can exploit. In this article, we will look at how information about these vulnerabilities can be used to gain normal user as well as root access to the machine. We will also look at the security measures

to be taken to prevent such vulnerabilities.

Let us use Sedna, a vulnerable Ubuntu based virtual machine designed for Hackfest2016, as MyCompany's Web server.

The various steps involved in the process are listed below.

Information gathering

- Finding services running on the server.
- Finding known vulnerabilities in the services.

Gaining user access

- Exploiting the vulnerabilities found in the service(s).

Privilege escalation

- Exploiting the vulnerabilities in the OS.

We have used the open source tools Nmap, Nikto, Searchsploit and Netcat, and the Firefox browser, though any other tool can also be used. All the tools mentioned are available on Kali Linux.

Hacking into MyCompany

To hack into an OS, first, a physical access or a network access is required.

As most Web servers offer access, we will therefore use this access. Let the IP address of our victim machine (MyCompany's Web server IP) be 192.168.187.140.

Information gathering using Network Mapper (Nmap)

All possible information about the victim's server should be gathered before starting the attack. This helps in deciding what vulnerabilities are easier and quicker to exploit. Therefore, information gathering tools like Nmap, Nessus, etc, are selected to get the services running on the victim using its IP address. Here, Nmap has been used.

Give the following command:

```
nmap <victim-ip-address>
```

The screenshot in Figure 1 shows various services running on the victim. Of all these services, http (port 80) is the easiest to exploit and is vulnerable most of the time. Including the -A